Proyecto práctico Inteligencia de la seguridad 2025-2026

Clara Contreras && Carlos Contreras

20/11/2025

Índice

1 Escenario 3

2 Objetivo general 3

3 Normas de seguridad y alcance 3

4 Fase 1: Planificación del ataque y huella digital 3

5 Fase 2: Configuración de red y detección de intrusos 4

6 Fase 3: Creación del Plan de Respuesta ante Incidentes (PRI) 4

7 Fase 4: Ejecución del ataque y respuesta (puesta en práctica del plan) 5

8 Fase 5: Generación y análisis de evidencias (forense) 5

9 Fases 5 y 6: Análisis Forense e Inteligencia de Amenazas 5

- 9.1 Informe Técnico Forense . . . 6
- 9.2 Informe de Ciberinteligencia . . . 6
- 9.3 Documento de metodología y proceso de Investigación . . . 7
- 9.4 Trabajo extra (opcional) . . . 7
- 9.5 Formato de entrega . . . 7

10 Fase 8: Plan de continuidad de negocio 7

1 Escenario

Una organización ficticia (*poned nombre, se valora creatividad*) expone servicios internos y endpoints (p. ej. web) en una red de laboratorio aislada. Dos equipos (Red y Blue) simulan un ciclo completo de ataque–detección–respuesta–forense–ciberinteligencia–continuidad.

2 Objetivo general

Planificar y ejecutar un ataque controlado contra el entorno de laboratorio, detectarlo y responder según un plan previo, generando y correlacionando evidencias para extraer conclusiones operativas y de negocio.

3 Normas de seguridad y alcance

- La actividad se realiza exclusivamente en un **laboratorio aislado** y con **activos autorizados**. Queda prohibido atacar sistemas reales o de terceros.
- Se evalúan metodología, detección, documentación y preservación de evidencias, así como complegidad del ataque/pistas dejadas.
- Tiempos, hitos y reglas de enfrentamiento (*Rules of Engagement, RoE*) deben estar acordados antes de comenzar.

4 Fase 1: Planificación del ataque y huella digital

Se presentarán 2 informes, ambos a través de la entrega del Aula Virtual.
Informe de hipótesis y desarrollo de ataque:

- Definir **objetivos**, **hipótesis de intrusión** y **criterios de éxito** del Red Team.
- Plantear **reconocimiento** (OSINT, huella digital y en red de laboratorio).
- Elaborar una **matriz de TTPs** (referenciables a MITRE ATT&CK) a intentar y a *rastrear* por Blue.
- Preparar y documentar un **plan de pruebas en máquina propia** para validar técnicas si el Blue limita la visibilidad o falta información (*plus* por incluirlo).
- Identificar **controles defensivos** esperados y **indicadores** que podrían generar (para coordinar con Fase 2).
- Documentar supuestos, limitaciones y riesgos del ejercicio.

Informe de requisitos a entregar al Blue Team:

- Definir **requisitos** de sistema esperados (arquitectura de red, SO, herramientas, servicios, versiones, puertos abiertos, etc).
- Indicar recursos esperados para soportar la arquitectura.

Queda terminantemente prohibida la comunicación entre equipos sobre el desarrollo del ataque, se valorarán easter eggs no identificados por parte del Blue.

5 Fase 2: Configuración de red y detección de intrusos

Requisitos:

- Crear **diagrama de red** (segmentos, sensores, puntos de captura).
- Desplegar y ajustar **Suricata** (reglas base, reglas personalizadas alineadas con las TTPs de Fase 1, umbrales y salidas).
- Establecer **captura de tráfico** con **Wireshark** en puntos clave y filtros de trabajo.
- (Opcional) Integrar **ELK/Elastic, Logstash/Beats, Wazuh** para ingesta, correlación y visualización.
- Asegurar **sincronización horaria** (NTP), **retención/rotación de logs** y separación de *roles* de acceso.
- Validar el **pipeline de alertas** con eventos sintéticos controlados.

6 Fase 3: Creación del Plan de Respuesta ante Incidentes (PRI)

Has definido previamente una empresa ficticia (sector, estructura tecnológica, activos críticos, amenazas probables) a la que vas a atacar en la Fase 4. A continuación, elabora el Plan de Respuesta a Incidentes (PRI) que esa empresa debe usar. Debes entregar la descripción de la empresa en un documento aparte para facilitar la comprensión y contextualización del equipo contrario.

Requisitos del plan:

1. **Introducción / alcance** - Breve enunciado del propósito del PRI. - Alcance técnico: qué sistemas, redes, datos cubre. - Exclusiones si las hay.
2. **Roles, responsabilidades y autoridad** - Define quién hace qué en cada fase del plan. - Autoridad para tomar decisiones críticas (aislamiento, paradas, restauraciones). - Mecanismo de escalamiento en cada nivel de gravedad.
3. **Fases del plan y actividades** Desarrolla para cada fase (preparación, detección / identificación / análisis, contención, erradicación, recuperación, lecciones aprendidas) las acciones, criterios de transición y salvaguardas. Para cada fase debes incluir:
   - objetivos específicos
   - actividades concretas (qué hacer)
   - criterios para pasar a la fase siguiente
   - riesgos a evitar y precauciones (especialmente forenses)
   - artefactos esperados (qué documentos, evidencias capturar)
4. **Comunicación interna y externa** - Canales y formatos para informar dentro del equipo, dirección y áreas afectadas. - Plantillas o guiones de comunicación externa (clientes, reguladores, prensa). - Condiciones que disparan notificaciones externas.

5. **Mecanismos de preservación de evidencia** - Procedimientos para asegurar cadena de custodia. - Cómo manejar evidencias volátiles y persistentes. - Reglas para no destruir evidencia durante la respuesta.

6. **Simulación, mantenimiento y mejora** - Frecuencia y tipos de ejercicios (tabletop, simulacros) para validar el plan. - Cómo se revisará y actualizará el plan tras incidentes. - Métricas que usarás para medir efectividad (por ejemplo, tiempo medio de detección, contención, recuperación).

7. **Diagramas de flujo o árbol de decisión** Representa gráficamente el flujo entre fases, puntos de retroceso y criterios de transición.

8. **Anexos (si lo crees útil)** Puedes incluir plantillas, listas de verificación, ejemplos de IOCs, cronologías sugeridas, etc., como apéndices.

7 Fase 4: Ejecución del ataque y respuesta (puesta en práctica del plan)

Requisitos:

- Red Team ejecuta las TTPs planificadas respetando las RoE y los límites del entorno.
- Blue Team aplica el **PRI**, monitorea con Suricata/ELK/Wireshark, y **documenta la cronología** ($T0 \rightarrow Tn$).
- Realizar **capturas de red** (Wireshark), **alertas/logs** (Suricata/ELK/Wazuh) y **volcados** de disco y memoria conforme al PRI.
- Registrar decisiones de **contención** y su justificación técnica.

8 Fase 5: Generación y análisis de evidencias (forense)

Requisitos:

- Formalizar **adquisición forense** (procedimientos, hashes, custodia) de las fuentes definidas.
- Construir **líneas de tiempo** a partir de imágenes de disco, memoria, logs y pcaps.
- Identificar **IoCs**, artefactos relevantes y patrones anómalos; estimar alcance e impacto técnico.
- Documentar **limitaciones**, **incertidumbre** y **nivel de confianza** en hallazgos.

9 Fases 5 y 6: Análisis Forense e Inteligencia de Amenazas

Durante la fase previa de monitorización del ataque en laboratorio, cada grupo ha recogido sus propias evidencias, incluyendo:

- Volcado de memoria RAM y memoria.

- Logs y alertas generadas por Wazuh y Suricata.
- Datos y eventos relevantes recogidos durante la monitorización de red.

A partir de esas evidencias, se debe realizar un análisis forense y de inteligencia para reconstruir el incidente, identificar indicadores de compromiso (IoCs) y elaborar las siguientes entregas:

9.1 Informe Técnico Forense

El informe debe incluir:

1. Contexto y descripción del incidente según la fase de monitorización realizada
2. Metodología empleada (fases, herramientas y criterios de análisis)
3. Línea temporal del incidente (timeline con eventos relevantes)
4. Hallazgos técnicos: procesos, conexiones, artefactos, modificaciones del sistema, persistencias, malware
5. Identificación y clasificación de IoCs (IPs, dominios, hashes, URLs, archivos, artefactos, etc.)
6. Correlación con alertas procedentes de Wazuh y Suricata
7. Síntesis final del análisis forense y evidencias concluyentes

9.2 Informe de Ciberinteligencia

A partir de los IoCs obtenidos, el informe debe contener:

1. Enriquecimiento de IoCs mediante fuentes OSINT
2. Uso de al menos una plataforma de inteligencia trabajada en clase (VirusTotal, MISP, AlienVault OTX, Malpedia, Shodan, etc.)
3. Análisis técnico-contextual de los indicadores y posible relación con campañas, malware o actores
4. Mapeo de tácticas y técnicas según MITRE ATT&CK
5. Síntesis de inteligencia: tipo de amenaza, posibles objetivos, nivel de sofisticación, macroconclusiones

9.3 Documento de metodología y proceso de Investigación

Debe documentar el proceso seguido:

1. Herramientas utilizadas (mínimo cinco de las trabajadas en clase)
2. Explicación del procedimiento, decisiones tomadas y justificación técnica
3. Pivoting entre IoCs (cómo un indicador condujo a otro)
4. Capturas, fragmentos de comandos, resultados parciales y razonamiento
5. Problemas o limitaciones encontrados durante el análisis

9.4 Trabajo extra (opcional)

Se valorarán todas aquellas aportaciones adicionales que demuestren iniciativa, profundidad técnica o capacidades analíticas avanzadas.

9.5 Formato de entrega

- Informe técnico y de inteligencia en PDF (recordad estructura típica de informes: Introducción, resumen ejecutivo, descripción del entorno, hallazgos encontrados variando segúninforme o ampliando a varias secciones, conclusiones y recomendaciones)
- Documento de metodología en PDF o Markdown
- Entrega clara, estructurada y técnicamente sólida

10 Fase 8: Plan de continuidad de negocio

Requisitos:

- Extraer **lecciones aprendidas** y **recomendaciones** técnicas y de proceso.
- Proponer **RTO/RPO**, estrategias de **resiliencia** (copias, redundancia, restauración) y **pruebas periódicas**.
- Definir **hoja de ruta** de endurecimiento, priorizada por riesgo y esfuerzo, con responsables y plazos.